

Warsaw, April 24, 2024

Decision

DKN.5131.32.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2023, item 775, as amended) in connection with Articles 7, 60, 101, and 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781) and Article 57(1)(a) and (h), Article 58(2)(e) and (i), Article 83(1) – (3), Article 83(4)(a) in connection with Article 24(1), Article 25(1), Article 32(1) and (2), Article 33(1) and (3), and Article 34(1), (2), and (4), as well as Article 83(5)(a) in connection with Article 5(1)(f) and Article 5(2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the processing of personal data by the Legislative Initiative Committee "StopLGBT" for the amendment of the Act of July 24, 2015, on Assemblies and certain other acts (Article 5(1) of the Act of June 24, 1999, on the execution of legislative initiatives by citizens) (Warsaw, Ogrodowa Street 28/30, apartment 104), the President of the Personal Data Protection Office,

1) finds that the Legislative Initiative Committee "StopLGBT" for the amendment of the Act of July 24, 2015, on Assemblies and certain other acts (Article 5(1) of the Act of June 24, 1999, on the execution of legislative initiatives by citizens) (Warsaw, Ogrodowa Street 28/30, apartment 104) violated the provisions:

- a) Article 24(1), Article 25(1), Article 32(1) and (2), Article 33(1) and (3), and Article 34(1) and (2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as "Regulation 2016/679", consisting of the failure to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing data collected on the list of citizens who support the draft law that is the subject of the legislative initiative, in order to protect that data against unauthorized or unlawful processing and against accidental loss, destruction, or damage and disclosure to unauthorized persons, as well as the failure to implement appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing, which resulted in a violation of Article 5(1)(f) of Regulation 2016/679 (principle of confidentiality) and Article 5(2) of Regulation 2016/679 (principle of accountability),
- b) Article 33(1) of Regulation 2016/679, consisting of the failure to notify the President of the Personal Data Protection Office of a personal data breach without undue delay, and no later than 72 hours after becoming aware of the breach,
- c) Article 34(1) of Regulation 2016/679, consisting of the failure to inform without undue delay the individuals whose data have been breached about the personal data breach,

imposes on the Legislative Initiative Committee "StopLGBT" for the amendment of the Act of July 24, 2015, on Assemblies and certain other acts (Article 5(1) of the Act of June 24, 1999, on the execution of legislative initiatives by citizens) (Warsaw, Ogrodowa Street 28/30, apartment 104) an administrative fine of 10,913 PLN (in words: ten thousand nine hundred thirteen zlotys) for the violation of Article 5(1)(f), Article 5(2), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679,

2) orders the Legislative Initiative Committee "StopLGBT" for the amendment of the Act of July 24, 2015, on Assemblies and certain other acts (Article 5(1) of the Act of June 24, 1999, on the execution of legislative initiatives by citizens) (Warsaw, Ogrodowa Street 28/30, apartment 104) to notify - within 3 days from the date of delivery of this decision - the individuals whose data were disclosed in

connection with the leaving in the church in C. the list of citizens who support the draft law that is the subject of the legislative initiative, without supervision, about the personal data breach in order to provide them with the information required under Article 34(2) of Regulation 2016/679, namely:

- a) a description of the nature of the personal data breach;
- b) the name and contact details of the data protection officer or another contact point from which more information can be obtained;
- c) a description of the possible consequences of the personal data breach;
- d) a description of the measures taken or proposed by the controller to address the breach - including measures to mitigate any possible negative effects.

Justification

On September 16, 2020, the President of the Personal Data Protection Office...
of the citizens supporting the legislative initiative.

II. According to Article 5(1) and (4) of the Act of June 24, 1999 on the execution of legislative initiatives by citizens (Journal of Laws of 2018, item 2120), activities related to the preparation of a draft law, its dissemination, promotional campaign, as well as the organization of collecting signatures from citizens supporting the draft, are carried out by the legislative initiative committee, hereinafter referred to as the "committee." The committee operates under a name supplemented by the title of the draft law and possesses legal personality, which it acquires upon the acceptance by the Marshal of the Sejm of the Republic of Poland of the notification referred to in Article 6(2) of the Act.

According to Article 9(2) of the aforementioned Act, a citizen supports the draft law by signing the list, next to their name(s), surname, residence address, and PESEL identification number, with their handwritten signature. Each page of the list must contain the name of the committee and the title of the draft law that the citizen supports. The template for the list of citizens supporting the draft law that is the subject of the legislative initiative is specified in the Regulation of the Prime Minister of September 28, 1999, on establishing the template for the list of citizens supporting the draft law that is the subject of the legislative initiative (Journal of Laws No. 79, item 893).

The aforementioned provisions, by stating that the execution of the legislative initiative is closely related to the collection of personal data of individuals supporting the draft law, in the scope specified in Article 9(2) of the above-mentioned Act, determine that the Committee is the administrator, within the meaning of Article 4(7) of Regulation 2016/679, of the data being processed.
to the context of the specific situation and the potential impact on the rights and freedoms of individuals whose personal data may have been affected. The assessment should consider the nature of the personal data involved, the circumstances of the breach, and the measures that were in place to protect the data.

III. The Administrator must also take into account the potential consequences of the breach for the individuals concerned, including the risk of identity theft, financial loss, or other forms of harm. It is essential that the Administrator implements a robust response plan to address any breaches that occur, including notifying the relevant supervisory authority and affected individuals when required by law.

IV. In accordance with Article 33 of Regulation 2016/679, in the event of a personal data breach, the Administrator must notify the supervisory authority without undue delay and, where feasible, within 72 hours of becoming aware of the breach. The notification must include details of the breach, including the nature of the personal data affected, the categories and approximate number of individuals concerned, the likely consequences of the breach, and the measures taken or proposed to address the breach.

V. Furthermore, if the breach is likely to result in a high risk to the rights and freedoms of individuals, the Administrator must also communicate the breach to the affected individuals without undue delay, as stipulated in Article 34 of Regulation 2016/679. This communication should be in clear and plain language, describing the nature of the breach and providing recommendations for individuals to protect

themselves from potential adverse effects.

VI. The Administrator is responsible for ensuring that all employees and relevant personnel are trained on data protection principles and the procedures to follow in the event of a data breach. Regular audits and assessments should be conducted to ensure compliance with the provisions of Regulation 2016/679 and to identify areas for improvement in data protection practices.

VII. In conclusion, the Administrator must take a proactive approach to data protection, implementing appropriate technical and organizational measures to safeguard personal data and ensure compliance with applicable laws and regulations. This includes regular reviews of data processing activities, risk assessments, and the establishment of clear protocols for responding to data breaches.

attention to the scope of personal data processed by him, which is included in the list of citizens who support the draft law that is the subject of the legislative initiative, the compliance with Article 9 of the Act on the Execution of Legislative Initiatives by Citizens does not exempt the Administrator from the obligation to take actions ensuring an appropriate level of data protection by implementing appropriate technical and organizational measures to ensure the security of this data. The nature and type of these actions should result from a conducted risk analysis, in which vulnerabilities related to the utilized resources and the threats arising from them should be identified, and then adequate security measures should be determined. An incorrect risk assessment or its omission prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence. As a result of the above, the risk materialized, resulting in unauthorized persons gaining access to the data recorded on the support cards for the legislative initiative undertaken by the Administrator. It should be noted that Regulation 2016/679 introduced an approach in which risk management is the foundation of actions related to the protection of personal data. Risk management is a continuous process that requires the data administrator not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to ensure accountability regarding the level and adequacy of the introduced safeguards. Therefore, it becomes necessary to demonstrate before the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk, as well as take into account the nature of the given organization and the mechanisms used for processing personal data. The Administrator must therefore conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Specific security measures and procedures are not indicated to the Administrators. In the judgment of August 26, 2020, case file II SA/Wa 2826/19, the Provincial Administrative Court in Warsaw indicated that "This provision [Article 32 of Regulation 2016/679] does not require the data administrator to implement any technical and organizational measures that are to constitute personal data protection measures, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but also the risk associated with the processing of this personal data, which may be characterized by varying degrees." Furthermore, the WSA states that "The adopted measures must be effective; in specific cases, some measures will have to be measures that mitigate low risk, while others must mitigate high risk; however, it is important that all measures (and each individually) are adequate and proportional to the degree of risk.", and also "(...) technical-organizational activities are the responsibility of the data administrator, but they cannot be selected in a completely free and voluntary manner, without taking into account the degree of risk and the nature of the protected personal data."

In light of the above, it is the appropriately conducted risk assessment that provides the administrator with the ability to determine and implement technical and organizational measures that will eliminate or at least significantly reduce (lower) the established level of risk of materialization of identified threats to the processed personal data. The risk assessment conducted by the administrator should be documented and justified by the factual state existing at the time of its conduct. The main factors constituting a proper assessment that should be taken into account during the analysis are the

characteristics of the processing processes, assets, vulnerabilities, threats, and current safeguards. It should be remembered that significant factors in assessing risk also include the scope and nature of the personal data processed by the administrator, as the potential negative consequences for the individual in the event of a breach of their personal data protection will depend on them.

The risk analysis conducted by the Administrator (without a date) identified three situations whose occurrence may pose a risk of violation of the rights or freedoms of individuals: unauthorized access to the room where personal data is processed, unauthorized copying of cards with signatures, and unauthorized transfer of information containing personal data. The risk for each of the mentioned vulnerabilities was assessed as "negligible," which, viewed through the prism of the categories of personal data contained in the support lists, including name, surname, and PESEL number along with data regarding the worldview of these individuals, and also considering the context of the situation in which the breach occurred, i.e., leaving the support cards for the Administrator's legislative initiative in the church without supervision, thus revealing the personal data of individuals supporting the Administrator's initiative, indicates a significant underestimation of the risk of negative consequences in the event of a security incident. In the context of a data breach, the second indicated category, i.e., unauthorized copying of cards with signatures, is significant. The Administrator indicated, demonstrate. It is also worth noting that the provisions of Regulation 2016/679 impose an absolute obligation on data controllers to ensure compliance with data protection laws, and it is the responsibility of the data controller to implement appropriate measures based on the nature, scope, context, and purposes of processing, as well as the risks to the rights or freedoms of individuals.

In summary, the Administrator's assertions regarding the implementation of security measures and the oversight of the signature collection process are undermined by the lack of evidence demonstrating effective control and compliance with the accountability principle outlined in Article 5(2) of Regulation 2016/679. The Administrator must take full responsibility for any failures in this regard, as highlighted by the relevant case law from the Warsaw Administrative Court.

demonstrate. These measures are reviewed and updated as necessary. Therefore, in accordance with the aforementioned provision of Regulation 2016/679, as well as the obligations arising from Article 25(1) and Article 32(1) and (2) of this regulation, it is the data controller, and not the volunteer, who is obliged to implement appropriate technical and organizational measures to ensure that processing is carried out in compliance with the requirements of Regulation 2016/679. As indicated by the Provincial Administrative Court in Warsaw in its judgment of February 15, 2022, case file II SA/Wa 3309/21, "An employee [here: volunteer] cannot replace the data controller in fulfilling their obligations arising from these provisions [i.e., Article 24(1), Article 25(1), and Article 32(1) of Regulation 2016/679]." From the cited judgment, it follows that the Administrator should not only effectively communicate to the volunteers an instruction containing regulations regarding the appropriate security of the personal data they collect, but should also verify whether each volunteer has understood its content and monitor compliance with these provisions by the volunteers as part of regular testing of the security measures implemented by the Administrator, including those of an organizational nature. In its judgment of June 6, 2023, case file II SA/Wa 1939/22, the Provincial Administrative Court in Warsaw stated that "(...) the obligation to regularly test technical and organizational measures securing the processing of personal data, in order to ensure a level of security commensurate with the risk, as understood in Article 32(1) introductory sentence of the GDPR, directly arises from the wording of letter d of the cited Article 32(1), while the obligation to document actions in this regard is established by the principle of accountability (Article 5(2) of the GDPR)." In turn, in its judgment of June 21, 2023, case file II SA/Wa 150/23, the Court emphasized that "(...) regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of processing is a fundamental obligation of the controller and the processor arising from Article 32(1)(d) of the GDPR. The Administrator is therefore obliged to verify both the selection and the level of effectiveness of the technical measures used at each stage of processing. The comprehensiveness of this verification should be assessed in light of its adequacy to the risks and proportionality in relation to the state of technical knowledge, the costs of implementation, and the nature, scope, context, and purposes of processing."

It should also be noted that there are inconsistencies in the explanations provided by the Administrator, who states that “The Committee indicated in the previous letter that a conversation was held with the person who conducted the collections in the area on behalf of the committee and the possibility of violating GDPR provisions was ruled out,” and subsequently emphasizes that “It is also impossible to determine who collected signatures in the church in C. and how many such persons there were.” It is important to highlight the fact that the inability to identify the individuals involved in collecting signatures for the initiative indicates a complete lack of control by the Administrator over the conducted signature collection and may lead to impersonation of volunteers collecting signatures for the initiative, which could result in a serious violation of the rights or freedoms of natural persons and far-reaching consequences of citizens providing a wide range of personal data to untrustworthy individuals, who may even use it for criminal purposes.

In light of the demonstrated irregularities in conducting the risk analysis for the process of collecting data from individuals who signed the list of citizens supporting the draft law, as well as in the selection of measures to ensure the security of personal data collected on the support cards for the legislative initiative, it should be concluded that the Legislative Initiative Committee #StopLGBT violated the principle of data confidentiality (Article 5(1)(f) of Regulation 2016/679) in connection with the breach of the obligations of the controller in implementing technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 (Article 24(1) of Regulation 2016/679), in order to provide the necessary safeguards for processing (Article 25(1) of Regulation 2016/679) and to ensure a level of security commensurate with the risk, including the ability to continuously ensure confidentiality and regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of processing (Article 32(1) of Regulation 2016/679) and the obligation to take into account the risks associated with processing, arising from unauthorized access to processed personal data, when assessing whether the level of security is appropriate (Article 32(2) of Regulation 2016/679). The breach of the confidentiality principle expressed in Article 5(1)(f) of Regulation 2016/679 is related to the breach of the accountability principle referred to in Article 5(2) of Regulation 2016/679.

III. According to Article 4(12) of Regulation 2016/679, “a personal data breach” means a security breach leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

Article 33(1) and (3) of Regulation 2016/679 states that in the event of a personal data breach, the controller shall without undue delay – where feasible, not later than 72 hours after becoming aware of the breach – notify the supervisory authority competent under Article 55, unless the breach is unlikely to result in a risk to the rights or freedoms of natural persons. The notification sent to the authority...

****Supervisory Authority Notification****

After 72 hours, an explanation of the reasons for the delay must be attached. The notification referred to in paragraph 1 must, at a minimum:

- a) describe the nature of the personal data breach, including, where possible, the categories and approximate number of individuals affected, as well as the categories and approximate number of personal data entries involved in the breach;
- b) include the name and contact details of the Data Protection Officer or indicate another point of contact from which more information can be obtained;
- c) describe the possible consequences of the personal data breach;
- d) describe the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate any potential negative effects.

In turn, Article 34(1) of Regulation 2016/679 states that in the event of a high risk to the rights or freedoms of natural persons resulting from a personal data breach, the controller is obliged to notify the affected individual without undue delay. According to Article 34(2) of Regulation 2016/679, the notification referred to in paragraph 1 of this article must describe the nature of the personal data breach in clear and plain language and include at least the information and measures referred to in Article 33(3)(b), (c), and (d) of Regulation 2016/679, namely:

- a) the name and contact details of the Data Protection Officer or indicate another point of contact from which more information can be obtained;
- b) a description of the possible consequences of the personal data breach;
- c) a description of the measures taken or proposed by the controller to address the personal data breach, including, where appropriate, measures to mitigate any potential negative effects.

The analysis of the notification received by the President of the Personal Data Protection Office (UODO) regarding the possibility of a personal data breach has shown that without a doubt, the incident involving the unattended list of citizens who support the draft law that is the subject of a legislative initiative, which contained personal data in the form of first name, last name, residential address, PESEL number, and handwritten signature, as well as allowing insight into the worldview of the individuals who signed such a list, due to the scope of the personal data, constitutes a breach of data confidentiality due to the possibility of unauthorized persons, including at least the notifier, accessing this data. Unauthorized access to the personal data contained in the aforementioned list, due to its display in a church in a publicly accessible place and without supervision by the person(s) responsible for collecting these signatures, undoubtedly indicates the occurrence of a personal data breach.

From the analysis of the aforementioned provisions, it follows that depending on the level of risk of infringement of the rights or freedoms of natural persons that the controller is dealing with, their obligations towards the supervisory authority and the individuals whose data is affected differ. If, as a result of the analysis, the controller determines that the likelihood of a risk to the rights or freedoms of natural persons is low, they are not obliged to report the breach to the President of the Personal Data Protection Office. The indicated breach must only be recorded in the internal register of breaches. In the case of identifying a risk of infringement of the rights or freedoms of natural persons, the controller is obliged to report the personal data breach to the President of UODO, as well as to make an entry in the internal register of breaches. The occurrence of a high risk of infringement of the rights or freedoms of natural persons, in addition to an entry in the register of breaches, requires the controller to take appropriate actions, both towards the supervisory authority (reporting the personal data breach) and also towards the individuals whose data is affected.

In the case of personal data breaches that may cause a high risk to the rights or freedoms of the individual whose data is affected, Regulation 2016/679 introduces an additional obligation for the controller to promptly notify the data subject, unless they have taken preventive measures before the breach occurred or remedial actions after the breach occurred (Article 34(3) of Regulation 2016/679).

As follows from the above, in the event of the controller detecting a personal data breach, it is first necessary to conduct an analysis regarding the occurrence of a risk to the rights or freedoms of natural persons. The controller is exempt from the obligation to notify the supervisory authority of the breach if the conducted assessment shows that there is at most a low probability of the occurrence of a risk to the rights or freedoms of natural persons. However, it should be noted that the supervisory authority may request the controller to justify the decision not to report the breach; therefore, the conclusions from the conducted analysis should be recorded in the internal register of breaches. It is worth recalling that in the Guidelines of the European Data Protection Board (EDPB) No. 9/2022 adopted on March 28, 2023, referred to as Guidelines 9/2022, there are recommendations regarding the reporting of personal data breaches to the supervisory authority.

It is important to emphasize that reporting personal data breaches by controllers constitutes an effective tool contributing to a real improvement in the security of personal data processing. By reporting a breach to the supervisory authority, controllers inform the President of UODO whether, in their opinion, there is a high risk of infringement of the rights or freedoms of the individuals whose data is affected and—if such a risk has occurred—whether they have provided the relevant information to the individuals affected by the breach.

exerts an influence. In justified cases, they may also convey information that, in their opinion, notification is not necessary due to the fulfillment of the conditions specified in Article 34(3)(a) and (b) of Regulation 2016/679. The President of the Personal Data Protection Office verifies the assessment

made by the data controller and may—if the controller has not notified the data subjects—request such notification from them. Reports of personal data breaches allow the supervisory authority to respond appropriately, which can mitigate the effects of such breaches, as the controller is obliged to take effective actions to ensure the protection of individuals and their personal data, which on one hand allows for the monitoring of the effectiveness of existing solutions, and on the other hand, the assessment of modifications and improvements aimed at preventing irregularities similar to those covered by the breach. Meanwhile, notifying individuals about a personal data breach provides the opportunity to convey information to those individuals regarding the risks associated with the breach and to indicate actions that these individuals can take to protect themselves from potential negative consequences of the breach (this enables the individual to make an independent assessment of the breach in the context of the possibility of materializing negative consequences for such an individual and to make a decision on whether to apply or refrain from applying remedial actions).

The risk of infringement of the rights or freedoms of individuals occurs when a breach of data protection may result in physical, material, or non-material harm to the individuals whose data has been breached. It should be noted that according to the content of Article 33(1) of Regulation 2016/679, the mere occurrence of a data breach associated with the risk of infringement of the rights or freedoms of individuals obliges the controller to notify the supervisory authority of the occurrence of the breach, regardless of whether its consequences have materialized. The same applies in the case of Article 34(1) of Regulation 2016/679—the obligation to notify the data subject is independent of the actual infringement of the rights or freedoms of individuals, as it is precisely through notifying the data subjects that the controller aims to prevent the unauthorized use of their data.

As indicated in Guidelines 9/2022, a breach of personal data protection can potentially lead to a range of negative consequences for individuals whose data is the subject of the breach. Among the possible consequences of a breach, the EDPB mentions: physical harm, material or non-material damages. Examples of such damages include, among others: discrimination, identity theft or identity fraud, financial losses, damage to reputation, breach of confidentiality of personal data, and significant economic or social harm. In this case, there is no doubt that due to the scope of the data covered by the subject breach of personal data protection, which includes the PESEL identification number along with the first and last name and information allowing for the understanding of the worldview of individuals who signed the list of citizens supporting the legislative proposal, there is a high probability of the occurrence of the aforementioned damages. It should also be noted that the scope of data contained in the list of citizens supporting the legislative proposal allows for the unequivocal identification of individuals who signed this list.

Above all, it should be emphasized that the occurred breach of personal data protection concerned the PESEL identification number, which is an eleven-digit numerical symbol that uniquely identifies an individual, containing, among other things: date of birth and gender designation, and thus is closely linked to the private sphere of the individual and is also subject to, as a national identification number, exceptional protection under Article 87 of Regulation 2016/679, being data of a special nature and requiring such special protection. The PESEL number serves as identifying data for each individual and is widely used in dealings with various institutions and in legal transactions. The PESEL number along with the first and last name unequivocally identifies an individual in a way that allows for attributing negative consequences of the breach (e.g., identity theft, loan fraud) to that specific individual. Furthermore, it should be taken into account that as a result of the subject breach of personal data protection, the PESEL number was disclosed to an unauthorized person along with the first and last name, which combination of data can be sufficient for "impersonating" the data subject and incurring obligations in the name and to the detriment of such a subject, e.g., financial obligations (see: <https://www.bik.pl/poradnik-bik/wyludzenie-kredytu-tak-dzialaja-oszusci> - where a case is described in which: "Only the first name, last name, and PESEL number were enough for the fraudsters to obtain several loans totaling tens of thousands of zlotys. Nothing else matched: neither the ID number nor the residential address").

It is worth citing one of the examples found in the European Data Protection Board Guidelines

01/2021[2] (case no. 14, p. 31), relating to the situation of "accidentally sending highly confidential personal data by mail." In the case described in the aforementioned guidelines, there was a disclosure of a social security number, which is equivalent to the PESEL number used in Poland. In this case, the EDPB had no doubts that the disclosed data regarding: first name and last name, email address, postal address, and social security number indicated a high risk of infringement of the rights or freedoms of individuals ("the involvement of their [the affected individuals'] social security number, as well as other, more basic personal data, further increases the risk, which..."). can be described as high"). EROD recognizes the importance of national identification numbers (in this case, the PESEL number), while also emphasizing that this type of personal data breach, thus encompassing data in the form of: first name and surname, email address, correspondence address, and social security number, requires the implementation of actions, namely: notifying the supervisory authority and informing the affected individuals about the breach.

The European Data Protection Board has no doubt that an individually assigned number that uniquely identifies a natural person should be subject to special protection, and its disclosure to unauthorized entities may involve a high risk of infringement of the rights or freedoms of natural persons.

EROD also points out that data that uniquely identifies a natural person may pose a high risk of infringement of rights or freedoms in other examples provided in Guidelines 01/2021. In points 65 and 66 of Guidelines 01/2021, it is stated: "(...) The breached data allows for the unequivocal identification of the individuals concerned and contains other information about them (including gender, date and place of birth); moreover, it may be used by an attacker to guess customers' passwords or to conduct a spear-phishing campaign targeting bank customers. For these reasons, it was deemed that the data breach is likely to result in a high risk of infringement of the rights and freedoms of all individuals whose data is concerned. Consequently, material damages (e.g., financial losses) and non-material damages (e.g., identity theft or fraud) may occur."

The Provincial Administrative Court in Warsaw also had similar doubts (that the disclosure of the PESEL number along with other personal data may pose a high risk of infringement of the rights or freedoms of natural persons), which was confirmed in its judgment of September 22, 2021, case file II SA/Wa 791/21, stating that "There is no doubt that the examples of harm cited in the guidelines may occur in the case of individuals whose personal data – in some cases together with the PESEL identification number or the series and number of the identity card – have been recorded on the disclosed recordings. The possibility of identifying individuals whose data has been breached based on the disclosed data is significant for such an assessment." Furthermore, the Court in the aforementioned ruling indicated that "The data was disclosed to unauthorized persons, which means that a security breach occurred leading to the unauthorized disclosure of personal data, and the scope of this data, which in some cases also includes the PESEL identification number or the series and number of the identity card, determines that there is a high risk of infringement of the rights or freedoms of natural persons."

Considering the above issues, it is also necessary to refer to the position of the Provincial Administrative Court in Warsaw expressed in its judgment of July 1, 2022, issued in case file II SA/Wa 4143/21. In the justification of this judgment, the Court stated that: "It should be agreed with the President of UODO that the loss of confidentiality of the PESEL number in conjunction with personal data such as: first name and surname, registered address, bank account numbers, and the identification number assigned to Bank customers - CIF number, is associated with a high risk of infringement of the rights or freedoms of natural persons. In the event of a breach of such data as first name, surname, and PESEL number, identity theft or forgery may occur, resulting in negative consequences for the individuals concerned. Therefore, the Bank in this case should have promptly, in accordance with Article 34(1) of the GDPR, notified the individuals concerned about the personal data breach, so as to enable them to take necessary preventive actions." It should also be noted the judgment of August 31, 2022, case file II SA/Wa 2993/21, in which the Provincial Administrative Court in Warsaw emphasized that "(...) the authority correctly assumed that there was a high risk of infringement of the rights and freedoms of individuals affected by the breach due to the possibility of

easy identification of individuals whose data was breached based on the disclosed data. This data includes first name and surname, correspondence address, phone number, and PESEL number of individuals holding Polish citizenship. In this situation, the administrator was obliged to notify without undue delay the individuals concerned about the breach.” Similarly, the Provincial Administrative Court in Warsaw expressed itself in judgments of November 15, 2022, case file II SA/Wa 546/22, and June 21, 2023, case file II SA/Wa 150/23.

From the latest infoDOK report[3] (which was prepared as part of the social Information Campaign of the RESTRICTED DOCUMENTS System, organized by the Polish Bank Association and some banks, under the patronage of the Ministry of Internal Affairs and Administration and in cooperation with, among others, the Police and the Consumers' Federation), it follows that in the second quarter of 2023, there were 2116 attempts to defraud loans and credits. In the entire year of 2020, there were 6884 attempts to defraud for a total amount of 253.8 million PLN, while in the entire year of 2021, there were 8096 attempts to defraud loans for a total amount of 336.6 million PLN. This means that the entire year of 2021 was significantly more dangerous in terms of the number of attempts to defraud and their amounts compared to the previous year: there was a 17% increase in the number of attempts to defraud and a 32% increase in the total amount of these attempts. As the report indicates, in 2022, the number of attempts to defraud loans remained at the level of 8079 attempts, and by mid-year, there had already been 4404 attempts to defraud loans for a total sum of 103.7 million PLN.

Moreover, as indicated by the case law, judgments in cases of loan fraud are not uncommon and have been issued by Polish courts in similar cases for a long time -

as an example, one can refer to the judgment of the District Court in Łęczyca dated July 27, 2016 (case file no. I C 566/15), in which fraudsters taking a loan using someone else's data used the PESEL number, a fictitious address, and an incorrect (invalid) ID number. In the justification of the aforementioned judgment, the Court stated: “In this case, the plaintiff (...) based in W. acquired the receivable from (...) Spółka z ograniczoną odpowiedzialnością S.K.A. based in W. The party to the loan agreement dated May 5, 2014, was a person who unlawfully used the data of J. R. (...) Spółka z ograniczoną odpowiedzialnością S.K.A. based in W. transferred the amount of 500 PLN to the indicated bank account. The key issue in this case was to establish that the defendant did not enter into a loan agreement, which was a claim raised by the defendant throughout the proceedings. The conducted evidentiary proceedings and the analysis of documents submitted by the plaintiff lead to the conclusion that in the case at hand, the defendant was not a party to the loan agreement concluded on May 5, 2014. Although the PESEL number of the defendant J. R. was used in its conclusion, the indicated place of residence does not correspond to the residence of the defendant. The defendant J. R. has never lived in W. The loan amount was transferred to an account that was not owned by the defendant. At the time of the conclusion of the loan agreement, the ID number (...) had expired on March 15, 2014. The mobile phone number indicated in the loan agreement and its attachments does not match the actual phone numbers used by the defendant. In the circumstances of the case at hand, the Court found that the defendant demonstrated that she was not a party to the loan agreement that is the subject of these proceedings. Agreements concluded using means of distance communication should require detailed, thorough verification, and such verification conducted in this case leads to the conclusion that the defendant was not a party to the loan agreement.” In another case (I C 693/16), the District Court in Zgierz ruled in its judgment dated November 4, 2016: “The personal data of the defendant in the form of his name and surname and PESEL number, which were consistent with the data of the defendant, did not indicate that the defendant expressed his will to enter into a loan agreement on December 17, 2014. It is not excluded that a person who unlawfully obtained access to the personal data of the defendant entered into a loan agreement on his behalf with the company (...) sp. z o.o S.K.A based in W. In this case, the defendant demonstrated that he never lived at the address indicated in the loan agreement and that the phone number and email address used to register on the website and submit the loan application belonged to him.” Similarly, courts have ruled in other such cases. As an example, one can cite judgments in which courts dismissed claims for payment of amounts for loans taken out by unknown persons using the personal data (name and surname and PESEL number) of the defendants: Judgment of the District Court for Łódź-Widzew in

Łódź dated August 13, 2020, in case file no. II C 1145/19, in which an unknown third party unlawfully obtained the defendant's PESEL number and ID number, while the remaining address data indicated in the loan agreement was false - "In the Court's assessment, the evidence offered by the defendant - especially the documents from the criminal case pending before the District Court in Tarnowskie Góry under case file no. VI K 383/16 - indicates that the loan agreement dated November 8, 2014, was concluded by a third party using some of the personal data of Z. A. [...] while the ID number provided in this agreement was a number that the defendant no longer used at the time of the conclusion of the loan agreement, as this ID had expired about 8 months earlier"; Judgment of the District Court in Pisz dated August 21, 2020, case file no. I C 260/20 - "[...] The Court found that when concluding the loan agreement, the defendant's data was unlawfully used and entered as the borrower's data, while it was not the defendant who was a party to the agreement. The defendant's position is confirmed by the notification he submitted regarding the commission of fraud to his detriment, as well as by the fact that the prosecutor's office is conducting proceedings in this matter against the person indicated by the defendant. It should be noted that also in the ongoing proceedings before this court for payment, case files no. I C 1/19 and I C 482/19, where E.M. also appeared as the defendant, and where financial obligations were incurred in his name and surname under the same circumstances as in this proceeding, final judgments dismissing the claims were also issued. In the Court's opinion, the circumstances of the conclusion of the agreement with the plaintiff, where the first name and surname of the borrower are identical and his PESEL number is the same, while there is a discrepancy regarding the remaining data resulting from the content of the defendant's ID, i.e., the series and number of this document, the address of residence, taking into account the fact that a criminal process is being conducted against a person who allegedly impersonated the defendant for the purpose of concluding distance agreements and incurring financial obligations in various institutions, clearly indicate that it was not the defendant who entered into the loan agreement with the plaintiff's predecessor; Judgment of the District Court in Puławy dated April 7, 2022, in case file no. I C 475/19, in which the Court unequivocally stated that "[...] the evidence allowing for the verification of the defendant as a party to the subject agreement is not constituted solely by the indication of his personal data: name, surname, PESEL number, a series and number of the identity card in the content of the agreement – particularly in situations where the loan is concluded via an online platform, and thus it is obvious that the lender does not have the ability to directly verify the identity of the other party, and the agreement itself is not confirmed by the borrower's signature."

"It is also noteworthy that, as indicated by the delivery receipt of the debit card, the identity card presented to the courier, number (...), was valid until September 21, 2019, while the original identity card belonging to Ł.B. (1) was valid until June 2, 2021 (k. 220), which confirms the defendant's testimony, also regarding the fact that a probable source of the 'leak' of his personal data was the sales agreement for a car concluded by him on June 8, 2017, which, in addition to the first and last name of the seller and his PESEL number, also includes the identity card number, whereas this agreement did not contain data regarding the names of the parents – and in the bank account agreement, this data is already incorrectly entered, as well as the expiration date of the identity card – this is also incorrectly entered in the delivery receipt of the bank account agreement, which clearly indicates that the person concluding the bank account agreement did not possess Ł.B. (1)'s data other than those contained in the car sales agreement, as well as the original identity card – which, as indicated by the defendant's testimony, is still in his possession and has not been made available to third parties."

It is also impossible to overlook that the analyzed violation of personal data protection also concerned the residential addresses of individuals who signed the list of citizens supporting the legislative initiative concerning the draft law. In light of the above, it is worth citing the judgment of the Supreme Administrative Court in Warsaw dated December 6, 2023, case file III OSK 2931/21: "The President of UODO correctly established that there was a disclosure of data, including first and last names, as well as PESEL numbers of individuals, and thus relatively permanent, unchanging data, the disclosure of which may always pose a risk of negative consequences for the aforementioned individuals. Similarly,

residential addresses are personal data, the unauthorized disclosure of which creates a high probability of negative legal consequences, regardless of the fact that the disclosure of addresses occurred several years after their update.” Furthermore, the fact of signing this document, due to the nature of the undertaking undertaken by the Administrator (collecting signatures for the civic draft law “Stop LGBT”), may indicate the signatory's worldview, and information in this regard constitutes data subject to special protection under Article 9(1) of Regulation 2016/679. It should be emphasized that in assessing the risk, a key factor is the type and sensitivity of the personal data disclosed as a result of the violation of personal data protection. In Guidelines 9/2022, it was emphasized that a collection of various personal data generally has a more sensitive nature than individual data.

The Administrator, in the submitted explanations, indicated that “the Committee was not informed of any personal data breaches, and the Committee itself did not identify such breaches.” Therefore, it must be borne in mind that the performance by the Administrator of his obligation under Article 34(1) of Regulation 2016/679 cannot be conditioned on the occurrence of a violation of the rights or freedoms of individuals whose data is concerned by the violation of personal data protection. The same applies to the obligation arising from Article 33(1) of Regulation 2016/679. As stated by the Provincial Administrative Court in Warsaw in its judgment of September 22, 2021, in case II SA/Wa 791/21: “It should be emphasized that the possible consequences of the event in question do not have to materialize. The content of Article 33(1) of Regulation 2016/679 indicates that the mere occurrence of a personal data breach, which is associated with a risk of infringement of the rights or freedoms of individuals, implies an obligation to report the breach to the relevant supervisory authority, unless it is unlikely that the breach will result in a risk of infringement of the rights or freedoms of individuals” (with this Court having similarly ruled in the previously referenced judgment of July 1, 2022, in case II SA/Wa 4143/21 and in judgments of August 31, 2022, case II SA/Wa 2993/21 and November 15, 2022, case II SA/Wa 546/22).

In applying the provisions of Regulation 2016/679, one must consider the purpose of this regulation (expressed in Article 1(2)), which is to protect the fundamental rights and freedoms of individuals, particularly their right to the protection of personal data. Moreover, the protection of individuals in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In the event of any doubts, for example, regarding the performance of obligations by administrators – including in situations where there has been a violation of personal data protection – these values should be taken into account first and foremost.

It is worth emphasizing that when assessing the risk of infringement of the rights or freedoms of individuals, which is a condition for reporting a personal data breach and notifying the individual whose data is concerned, both the probability factor and the weight of potential negative consequences must be considered together. A high level of either of these factors affects the overall assessment, which is a condition for fulfilling the obligations specified in Article 33(1) and Article 34(1) of Regulation 2016/679. Given that due to the scope of the personal data contained in the list of citizens who support...

the draft law that is the subject of the legislative initiative, and the fact that signing this list may reveal the worldview of the signer, and this list was left in the church in C. without any supervision from the person(s) responsible for collecting these signatures, there was a possibility of serious negative consequences for the individual whose data is concerned (as demonstrated above). Consequently, the significance of the potential impact on the rights or freedoms of the individual must be regarded as high. At the same time, the likelihood of a high risk occurring as a result of the infringement in question is not small and has not been eliminated. Therefore, it must be stated that in connection with the infringement in question, there is a high risk of violating the rights or freedoms of the individual whose data is concerned, which consequently determines the obligation to report the personal data breach to the supervisory authority and to notify the individuals who signed the aforementioned list.

In Guidelines 9/2022, the EDPB indicates the factors to be considered when assessing risk, referring to recitals 75 and 76 of Regulation 2016/679, which suggest that the controller should take into account both the likelihood of occurrence and the severity of the threat to the rights or freedoms of the

individual whose data is concerned. In the case of a personal data breach, the controller should focus on the risk of impact on the individual resulting from the breach. Thus, when assessing the risk to the individual arising from the personal data breach, the controller should consider the specific circumstances of the breach, including the severity of the potential impact and the likelihood of its occurrence. In this regard, when assessing risk, the EDPB recommends taking into account criteria such as: the type of breach, the nature, sensitivity, and amount of personal data, as well as the ease of identification, as these may affect the level of risk to individuals. The risk of infringement of the rights and freedoms of the individual, according to Guidelines 9/2022, will be greater when the consequences of the breach are more serious, as well as when the likelihood of their occurrence increases. The guidelines indicate that in case of any doubts, the controller should report the breach, even if such caution might seem excessive.

In summary of the above considerations, it must be stated that in this case there is a high risk of violating the rights or freedoms of the individuals affected by the infringement, which in turn results in the Committee's obligation to report the personal data breach to the supervisory authority, in accordance with Article 33(1) of Regulation 2016/679, which must include the information specified in Article 33(3) of Regulation 2016/679, as well as to notify the individual of the breach, in accordance with Article 34(1) of Regulation 2016/679, which must include the information specified in Article 34(2) of Regulation 2016/679.

Referring to the obligation of the Controller specified in Article 34(2) of Regulation 2016/679, the President of the UODO stated that the Controller (taking into account the nature of the breach and the categories of data that were breached) should inform the individuals whose data is concerned of the most likely negative consequences of the breach of their personal data. Certainly, in the case of a breach of such data as name, surname, and PESEL identification number, it should primarily be pointed out the possible theft or falsification of identity through obtaining loans from non-bank institutions or fraudulently obtaining insurance or funds from insurance, which may lead to negative consequences related to attempting to attribute to the individual whose data has been breached responsibility for committing such fraud. The description of possible consequences should reflect the risk of infringement of the rights or freedoms of that individual, so as to enable them to take necessary preventive actions.

In a situation where, as a result of a personal data breach, there is a high risk of violating the rights or freedoms of individuals, the controller is obliged to implement all appropriate technical and organizational measures to immediately identify the personal data breach and quickly inform the supervisory authority, as well as the individuals whose data is concerned. The controller should fulfill this obligation as soon as possible.

Recital 85 of the preamble to Regulation 2016/679 explains: "In the absence of appropriate and timely action, a personal data breach may result in physical harm, material or non-material damage to individuals, such as loss of control over their personal data or restriction of rights, discrimination, identity theft or fraud, financial loss, unauthorized reversal of pseudonymization, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, or any other significant economic or social damage. Therefore, immediately after identifying a personal data breach, the controller should report it to the supervisory authority without undue delay, if feasible, no later than 72 hours after the breach is identified, unless the controller can demonstrate in accordance with the principle of accountability that it is unlikely that the breach could result in a risk to the rights or freedoms of individuals. If it is not possible to report within 72 hours, the report should be accompanied by an explanation of the reasons for the delay, and information may be provided gradually, without further undue delay."

In turn, Recital 86 of the preamble to Regulation 2016/679 states: "The controller should without... the obligation to notify the data subject without undue delay about the breach of personal data protection, if it may result in a high risk of infringement of the rights or freedoms of that person, so as to enable that person to take necessary preventive measures. Such information should include a description of the nature of the personal data breach and recommendations for the individual on

minimizing potential adverse effects. Information must be communicated to the data subjects as quickly as reasonably possible, in close cooperation with the supervisory authority, respecting the guidance provided by that authority or other relevant bodies, such as law enforcement agencies. For example, the need to minimize the immediate risk of harm will require the prompt notification of the data subjects, while the implementation of appropriate measures against similar or related breaches of data protection may justify a later notification.

By notifying the data subjects without undue delay, the controller enables the individual to take necessary preventive actions to protect their rights or freedoms from the negative effects of the breach. Article 34(1) and (2) of Regulation 2016/679 aims not only to ensure the most effective protection of the fundamental rights or freedoms of data subjects but also to implement the principle of transparency, which arises from Article 5(1)(a) of Regulation 2016/679 (see Witold Chomiczewski [in:] GDPR. General Data Protection Regulation. Commentary, ed. E. Bielak-Jomaa, D. Lubasz, Warsaw 2018). Proper fulfillment of the obligation specified in Article 34 of Regulation 2016/679 is intended to provide data subjects with quick and transparent information about the breach of their personal data, along with a description of the possible consequences of the personal data breach and the measures they can take to minimize its potential negative effects. By acting in accordance with the law and demonstrating care for the interests of the data subjects, the controller should have provided the data subjects with the best possible protection of personal data without undue delay. To achieve this goal, it is essential at least to indicate the information listed in Article 34(2) of Regulation 2016/679, which the controller failed to fulfill. Therefore, by deciding not to notify the supervisory authority and the data subjects about the breach, the controller effectively deprived those individuals of timely, reliable information about the personal data breach and the opportunity to counteract potential damages.

As a rule, the controller should individually notify the data subjects about the personal data breach. However, if the controller does not have a list of citizens who support the draft law that is the subject of the legislative initiative, or a copy thereof, and thus is unable to identify the data subjects, then in accordance with Article 34(3)(c) of Regulation 2016/679, they should notify those individuals by issuing a public announcement or using a similar measure to inform the data subjects about the breach in an equally effective manner.

Consequently, it should be stated that the controller did not report the personal data breach to the supervisory authority in fulfillment of the obligation under Article 33(1) of Regulation 2016/679 and did not notify the data subject without undue delay about the breach of their data protection, in accordance with Article 34(1) of Regulation 2016/679, which constitutes a violation of these provisions by the controller.

Assessing the circumstances of the personal data breach in question, it should be emphasized that when applying the provisions of Regulation 2016/679, it is necessary to keep in mind that the purpose of this regulation (expressed in Article 1(2)) is to protect the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, and that the protection of individuals in relation to the processing of personal data is one of the fundamental rights (first sentence of Recital 1 of the preamble). In case of any doubts, for example, regarding the fulfillment of obligations by controllers – not only in situations where a personal data breach has occurred but also when developing technical and organizational security measures to prevent them – these values should be taken into account first.

According to Article 34(4) of Regulation 2016/679, if the controller has not yet notified the data subject about the personal data breach, the supervisory authority – taking into account the likelihood that the personal data breach will result in a high risk – may require them to do so or may determine that one of the conditions referred to in paragraph 3 has been met. Furthermore, from the content of Article 58(2)(e) of Regulation 2016/679, it follows that each supervisory authority has the corrective power to order the controller to notify the data subject about the personal data breach.

Considering the above findings and the identified violations of the provisions of Regulation 2016/679, the President of the Personal Data Protection Office (UODO), exercising the authority granted to him

under Article 58(2)(i) of Regulation 2016/679, according to which each supervisory authority has the power to apply, in addition to or instead of other corrective measures provided for in Article 58(2)(a)-(h) and (j) of this regulation, an administrative fine under Article 83(4)(a) and (5)(a) of Regulation 2016/679, taking into account the circumstances established in the proceedings, determined that in the case at hand there were grounds justifying the imposition on the controller...

administrative monetary penalty.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the controller and the processor, referred to in Articles 8, 11, 25-39, and 42 and 43, are subject, in accordance with paragraph 2, to an administrative monetary penalty of up to 10,000,000 EUR, and in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject, in accordance with paragraph 2, to an administrative monetary penalty of up to 20,000,000 EUR, and in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Article 83(3) of Regulation 2016/679 states that if the controller or the processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty shall not exceed the amount of the penalty for the most serious violation.

In this case, the administrative monetary penalty imposed on the Controller was for the violation of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, it was based on Article 83(5)(a) of that regulation. At the same time, the administrative monetary penalty in the amount of 9432 PLN (in words: nine thousand four hundred thirty-two zloty) imposed on the Controller for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the penalty for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative monetary penalty of up to 20,000,000 EUR, and in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous financial year.

In deciding to impose the administrative monetary penalty, the President of the UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which aggravate the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data are concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The violation of personal data protection regulations identified in this case, resulting from unauthorized access to data contained in the list of citizens supporting the draft law that is the subject of legislative initiative, is of significant weight and serious nature.

Reporting violations of personal data protection by data controllers is an effective tool contributing to a real improvement in the security of personal data processing. Based on the information provided by controllers in the reports of personal data breaches, the supervisory authority can assess whether the controller has properly analyzed the impact of the breach on the rights or freedoms of the individuals whose data are subject to the breach, and consequently, whether there is a high risk of infringement of the rights or freedoms of natural persons and whether there is a need to notify those individuals of the breach of their data. Properly executed obligations by Controllers as defined in Article 33(1) and Article 34(2) of Regulation 2016/679 also allow for the mitigation of the negative effects of such breaches and the elimination or at least limitation of the risk of such breaches occurring in the future, as controllers are obliged to take actions that ensure proper protection of personal data by implementing appropriate security measures and monitoring their effectiveness. It should be noted that the failure to notify individuals who signed the list of citizens supporting the draft law that is the subject of legislative

initiative about the breach of their personal data results in depriving them of the opportunity to independently secure their personal data against the materialization of negative consequences of such a breach.

On the other hand, the violation by the Controller of the obligations to apply appropriate security measures to protect the processed data from being disclosed to unauthorized persons entails not only a potential but also a real possibility of those data being used by third parties without the knowledge and against the will of the individuals whose data are concerned, in violation of the provisions of Regulation 2016/679. It should be emphasized that the wide range of personal data contained in the list of citizens supporting the draft law that is the subject of legislative initiative, due to the lack of any oversight of this list by the person(s) responsible for collecting signatures, may lead to significant consequences in the form of material and non-material damage associated with the disclosure of, in particular, PESEL numbers and data subject to special protection under the provisions of Regulation 2016/679, i.e., data.

concerning the beliefs of the individuals whose data is being processed. As indicated by the District Court in Warsaw in the judgment dated August 6, 2020, case file no. XXV C 2596/19, the fear, and thus the loss of security, constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in its ruling dated December 14, 2023, in the case of *Natsionalna agentsia za prihodite (C-340/21)* emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the fear of potential misuse of personal data by third parties, which a data subject experiences following a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

Recital 51 of Regulation 2016/679 indicates that personal data, which by their nature are particularly sensitive in light of fundamental rights and freedoms, require special protection, as the context of their processing may pose serious risks to fundamental rights and freedoms. Therefore, the Administrator, while carrying out activities related to the collection of signatures for the draft law, should apply the highest standards, particularly in terms of the security of the processed data. Meanwhile, the Administrator, conducting the collection of signatures without monitoring compliance with the security measures established in connection with the planned data processing, allowed a breach of data confidentiality by leaving it unsupervised by the person(s) responsible for collecting signatures. This situation indicates a dismissive attitude of the Administrator towards citizens who decided to support the draft law. It is necessary to reiterate the explanations of the Administrator, who states that "(...) it is not possible to 'demonstrate' that individuals were familiar with the instruction [for collecting signatures], as it is impossible to even determine the identities of the individuals, of whom there were thousands nationwide, who participated in the signature collection," which undoubtedly indicates improper implementation of the security measures prepared by the Administrator.

It should also be emphasized that the duration of the breach of the provisions of Regulation 2016/679 was long, as it should be assumed that the breach began in the second half of 2020 and ended on July 26, 2021, i.e., on the day the draft law was submitted to the Sejm of the Republic of Poland (with respect to the breach of those provisions of Regulation 2016/679 that impose obligations on the administrator regarding the application of appropriate security measures; the breach of the provisions of Article 33(1) and Article 34(1) of Regulation 2016/679 continues, as the Administrator did not report the breach of personal data protection to the supervisory authority and did not notify the individuals whose data is being processed). Considering this premise, it should also be noted that the breach may have concerned the data of approximately 140,000 individuals who signed the list of citizens supporting the draft law that is the subject of the legislative initiative (<https://www.sejm.gov.pl/sejm10.nsf/PrzebiegProc.xsp?nr=26>), and in the case of the list located in the church in C., at least 17 individuals.

2. Intentional or unintentional nature of the breach (Article 83(2)(b) of Regulation 2016/679). I. According to the Guidelines of the Article 29 Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP253 (adopted on October 3, 2017, approved by EROD on May 25, 2018), intent "includes both knowledge and deliberate action, in

relation to the characteristics of the prohibited act." The Administrator made a conscious decision not to notify both the President of the UODO and the individuals whose data is being processed about the breach of personal data protection. There is no doubt that the Administrator, processing personal data in connection with undertaking the initiative of collecting signatures for a citizens' draft law, should have knowledge regarding personal data protection, including the consequences of identifying a breach of personal data protection resulting in a high risk of infringement of the rights or freedoms of individuals. Being aware of this, the Administrator nevertheless decided to refrain from reporting the breach of personal data protection to the President of the UODO and notifying the individuals whose data is being processed, despite the fact that the President of the UODO initially informed him of the obligations imposed on the administrator in connection with the breach of data protection. Finally, the mere initiation by the President of the UODO of this proceeding regarding the obligation to report the breach of personal data protection to the supervisory authority and to notify the individuals whose data is being processed should have raised at least doubts for the Administrator regarding the correctness of his position. The above indicates an intentional breach of the provisions of Article 33(1) and Article 34(1) of Regulation 2016/679.

II. Unauthorized access to the personal data of individuals whose data is on the list of citizens supporting the draft law that is the subject of the legislative initiative became possible due to the failure to exercise due diligence by the Committee. In the assessment of the supervisory authority, this constitutes an unintentional nature of the breach of the provisions of Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679, resulting from the negligence of the Administrator, as he had a risk analysis in which he anticipated the risk in the form of the possibility of copying personal data contained in the aforementioned list along with the identification of organizational measures guaranteeing, in the Administrator's assessment, an appropriate level of data security, as well as the instruction for collecting signatures for the draft law. Despite its preparation, the Administrator did not take actions leading to its proper implementation, and what moreover, it stated the lack of possibility to implement the measures it had adopted, thus violating Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

3. Actions taken to minimize the damage suffered by the data subjects (Article 83(2)(c) of Regulation 2016/679). Based on the evidence gathered in the case confirming the occurrence of harm to the data subjects, no actions were found to have been taken by the Administrator, not even those provided for in Article 34 of Regulation 2016/679.

4. The degree of cooperation with the supervisory authority in order to remedy the breach and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). In this case, the President of UODO deemed the cooperation from the Administrator to be unsatisfactory. This assessment pertains to the Administrator's response to the letters from the President of UODO informing about the obligations imposed on the administrator in connection with the data protection breach, and finally regarding the initiation of administrative proceedings concerning the obligation to report the personal data breach and notify the data subject about the breach. The actions deemed correct by the President of UODO (reporting the breach to the President of UODO and notifying the affected individuals about the breach) were not taken by the Administrator even after the President of UODO initiated administrative proceedings in the matter.

5. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data contained in the list of citizens who support the draft law that is the subject of the legislative initiative, left in the church in C. without the supervision of the person(s) collecting signatures, include data regarding first names, surnames, PESEL identification numbers, addresses of residence, and handwritten signatures. The nature of the undertaking undertaken by the Administrator (collecting signatures for the civic draft law "Stop LGBT") may, however, indicate (reveal) the worldview of the individuals signing this list, and information in this regard constitutes data subject to special protection under Article 9(1) of Regulation 2016/679.

It should also be noted that the list of citizens who support the draft law that is the subject of the legislative initiative contains the PESEL number, which is an eleven-digit numerical symbol that

uniquely identifies a natural person, containing the date of birth, ordinal number, gender designation, and control number, and thus is closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679. It is data of a special nature and requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as identifying data for each person and is commonly used in dealings with various institutions and in legal circulation. The PESEL number, along with the first name and surname, uniquely identifies a natural person in a way that allows for the attribution of negative consequences of the breach (e.g., identity theft, loan fraud) to that specific individual.

In this context, it is worth recalling the EROD 04/2022 guidelines, which state: "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679), the [Regulation 2016/679] clearly indicates the types of data that are subject to special protection, and thus a more rigorous response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 [of Regulation 2016/679] and data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the data subject (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the greater the number of such categories of data affected by the breach or the more sensitive the data, the greater weight the supervisory authority may assign to such a factor. The amount of data concerning each data subject is also significant; the larger the scale of the breach of the right to privacy and personal data protection."

It is also worth pointing out the developing case law in this area, where, for example, in the judgment of November 15, 2022, case reference II SA/Wa 546/22, the Provincial Administrative Court in Warsaw stated: "It was also obvious that the authority, when determining the amount of the penalty, had to take into account the fact that the breach concerned data of great sensitivity (including PESEL, address, health data)." This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in the case reference II SA/Wa 150/23, where the WSA in Warsaw stated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of violation of the rights or freedoms of natural persons."

In determining the amount of the administrative monetary penalty, the President of UODO found no grounds to consider mitigating circumstances that would affect the final amount of the penalty. All the criteria listed in Article 83(2)(a)-(j) of Regulation 2016/679, in the opinion of the supervisory authority, constitute either aggravating factors or merely neutral ones. Also, applying the criterion mentioned in Article 83(2)(k) of Regulation 2016/679 (which requires consideration of all other aggravating or mitigating factors applicable to the circumstances of the case), no mitigating circumstances were found, only neutral ones (as noted below in point 6 regarding...

ach ust. 2 lit. I rozporządzenia 2016/679). Prezes UODO nie stwierdził żadnych dodatkowych okoliczności obciążających ani łagodzących, które mogłyby wpłynąć na wymiar nałożonej administracyjnej kary pieniężnej. W związku z tym, w ocenie Prezesa UODO, nie ma podstaw do uwzględnienia jakichkolwiek innych czynników w kontekście wymiaru kary.

8. Wnioski. Na podstawie powyższych ustaleń, Prezes UODO stwierdził, że administrator naruszył przepisy art. 25 ust. 1 oraz art. 32 ust. 1 i 2 rozporządzenia 2016/679, co skutkuje nałożeniem administracyjnej kary pieniężnej. Wymiar kary został określony na podstawie analizy wszystkich okoliczności sprawy, w tym stopnia odpowiedzialności administratora oraz braku wcześniejszych naruszeń.

9. Zobowiązania. Administrator zobowiązany jest do podjęcia działań mających na celu usunięcie stwierdzonych naruszeń oraz wdrożenie odpowiednich środków technicznych i organizacyjnych, które zapewnią zgodność z przepisami o ochronie danych osobowych w przyszłości.

10. Odwołanie. Administrator ma prawo do złożenia odwołania od niniejszej decyzji w terminie 14 dni od dnia jej doręczenia, zgodnie z obowiązującymi przepisami prawa.

11. Postanowienia końcowe. Niniejsza decyzja wchodzi w życie z dniem doręczenia. Prezes UODO zastrzega sobie prawo do monitorowania działań podjętych przez administratora w celu zapewnienia zgodności z przepisami o ochronie danych osobowych.

the provisions of Article 83 of Regulation 2016/679 – an administrative fine in the amount of 10,913 PLN (ten thousand nine hundred thirteen zlotys).

The President of the Personal Data Protection Office, having thoroughly examined the case, did not note any circumstances other than those described above that could affect the assessment of the violation and the amount of the imposed administrative monetary penalty.

In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty applied fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it will be effective, proportionate, and deterrent in this individual case. According to the President of the Personal Data Protection Office, the administrative monetary penalty imposed on the Committee will be effective, as it will lead to a situation in which the Committee will implement technical and organizational measures that ensure a level of security for the processed data corresponding to the risk of violation of the rights or freedoms of the individuals concerned and the severity of the threats associated with the processing of such personal data. The effectiveness of the administrative monetary penalty is therefore equivalent to the guarantee that the Administrator, from the moment of the conclusion of this proceeding, will approach the requirements set by the personal data protection regulations with the utmost diligence.

The administrative monetary penalty applied is also proportionate to the established violation, especially in terms of its severity, impact, the scope of affected individuals, and the very high risk of negative consequences that arise in connection with the violation. In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty imposed on the Committee will not constitute an excessive burden for it. The amount of the penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, does not lead to a situation where the necessity to pay it would result in negative consequences in the form of a significant deterioration of the Administrator's financial situation. In the opinion of the President of the Personal Data Protection Office, the Committee should and is able to bear the consequences of its negligence in the area of data protection; hence, the imposition of an administrative monetary penalty in the amount of 10,913 PLN is fully justified.

Referring to the amount of the administrative monetary penalty imposed on the Committee, it should be noted that the Administrator does not belong to the group of entities listed in Article 102(1) and (2) of the Personal Data Protection Act, and therefore, in this case, the limitations on the amount (up to 10,000 or 100,000 PLN, respectively) of the administrative monetary penalty do not apply.

Consequently, pursuant to Article 101 of the Personal Data Protection Act, the administrative monetary penalty is imposed on the Administrator based on and under the conditions specified in Article 83 of Regulation 2016/679. However, considering that the Administrator is also not an entrepreneur, the determination of the amount of the imposed administrative monetary penalty did not occur by reference to the total annual global turnover from the previous financial year.

The Administrator, despite being twice summoned at the addresses provided on its website (the Administrator did not notify the supervisory authority of a change of address), did not submit the annual financial report. Consequently, the President of the Personal Data Protection Office determined the basis for calculating the administrative monetary penalty imposed on the Administrator in an estimated manner, taking into account its size and the specificity of the conducted activity, in accordance with Article 101a(2) of the Personal Data Protection Act.

Regarding the amount of the imposed administrative monetary penalty, the President of the Personal Data Protection Office considered that it is, in this specific case, deterrent and proportionate to the violations that occurred. It is worth emphasizing that the amount of the imposed administrative monetary penalty, i.e., 10,913 PLN, is only 0.01% of the maximum amount of the penalty that the

President of the Personal Data Protection Office could impose on the Administrator for the violations identified in this case – applying, in accordance with Article 83(5) of Regulation 2016/679, the static maximum penalty (i.e., 20,000,000 euros).

In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty will serve a repressive function in these specific circumstances, as it will constitute a response to the Committee's violation of the provisions of Regulation 2016/679, but it will also serve a preventive function, as it will contribute to preventing future violations by the Committee, as well as by other administrators, of the obligations arising from the personal data protection regulations.

In the opinion of the President of the Personal Data Protection Office, the administrative monetary penalty applied meets, in the established circumstances of this case, the criteria referred to in Article 83(1) of Regulation 2016/679, due to the severity of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of confidentiality and integrity expressed in Article 5(1)(f) of Regulation 2016/679 and the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

Pursuant to the provisions of Article 103 of the Personal Data Protection Act, the equivalent amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that in a given year the National Bank of Poland does not announce the average euro exchange rate on January 28 – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date. Keeping this in mind, the President of the Personal Data Protection Office, based on Article 83(4)(a) and Article 83(5)(a) in conjunction with Article 83(3) of Regulation 2016/679 and in connection with Article 103 of the Act of May 10, 2018, on personal data protection, for the violation described in the operative part of this decision, imposed on the Committee – applying... average exchange rate of the euro on January 29, 2024 (1 EUR = 4.3653 PLN) – an administrative monetary penalty in the amount of 10,913 PLN (which is equivalent to 2,500 EUR). The purpose of the imposed administrative monetary penalty is to ensure compliance by the Committee with the provisions of Regulation 2016/679 in the future, and consequently to conduct data processing activities in accordance with applicable legal regulations. In this factual and legal context, the President of the Personal Data Protection Office ruled as stated in the operative part.

[1] The aforementioned guidelines updated and supplemented the Guidelines of the Article 29 Working Party on reporting personal data breaches in accordance with Regulation 2016/679 (Wp250 rev.01), adopted on October 3, 2017.

[2] Guidelines of the European Data Protection Board 01/2021 on examples regarding the notification of personal data breaches adopted on December 14, 2021, version 2.0 (hereinafter "Guidelines 01/2021").

[3] <https://www.zbp.pl/getmedia/45bb9af8-95a4-4cc2-9767-05c73e5b1eb3/Raport-InfoDOK-II-kwartal-2023>

Print article

Metadata

Providing entity:

Department of Control and Violations

Created by:

Mirosław Wróblewski

2024-04-24

Entered by:

Wioletta Golańska

2024-04-29 12:39:36

Last modified by:

Edyta Madziar
2024-05-20 13:00:07